

Carraway Medical Center

Document Title:	Incident Response Policy
Document Owner:	Tia Mitchell
Version:	CMC-IRP-001
Last Review Date:	03/31/2026
Next Review Date:	09/31/2026
Approved By:	

1. Management Commitment

Carraway Medical Center (CMC) senior leadership is committed to establishing, maintaining, and continuously improving an effective incident response capability to protect the confidentiality, integrity, and availability of organizational systems and data.

Management shall ensure that appropriate resources, personnel, and technologies are allocated to support timely detection, reporting, analysis, and response to security incidents.

All workforce members, contractors, and third parties are required to comply with this policy. Failure to adhere to this policy may result in disciplinary action in accordance with organizational standards and applicable regulations.

2. Purpose and Objectives

The purpose of this policy is to establish a standardized approach for identifying, reporting, assessing, and responding to information security incidents that may impact Carraway Medical Center (CMC) operations, systems, or data. This policy aims to minimize the impact of security incidents, ensure timely response and recovery, and support compliance with applicable regulatory, legal, and industry requirements, including healthcare data protection obligations.

3. Scope

This policy applies to all Carraway Medical Center (CMC) workforce members, including employees, contractors, vendors, and third-party service providers, who have access to CMC systems or data. This policy also applies to all information systems, applications, networks, devices, and cloud-based environments owned, operated, or managed by CMC. All individuals and entities within scope are required to comply with this policy in the identification, reporting, and response to information security incidents that may impact CMC operations, services, or data. This policy applies to all environments where CMC data is stored, processed, or transmitted.

4. Definitions

- **Incident** – A confirmed or suspected event that compromises or has the potential to compromise the confidentiality, integrity, or availability of Carraway Medical Center (CMC) systems, data, or operations.
- **Breach** – A type of security incident involving the unauthorized access, use, disclosure, modification, or destruction of sensitive data, including Protected Health Information (PHI).
- **Event** – Any observable occurrence within a system or network. Events may be benign or may indicate suspicious or malicious activity requiring further investigation.
- **Outage** – An unplanned interruption or degradation of system availability that impacts the delivery of CMC services or operations.
- **HIPAA** – The Health Insurance Portability and Accountability Act, a U.S. regulation that establishes requirements for protecting the privacy and security of Protected Health Information (PHI).
- **NIST** – The National Institute of Standards and Technology, a U.S. organization that develops cybersecurity standards, guidelines, and frameworks used to manage and reduce risk.
- **Insider Threat** – A security risk originating within the organization, involving a trusted individual who intentionally or unintentionally misuses access to compromise systems or data.

5. Organizational Structure, Roles, and Responsibilities

Carraway Medical Center (CMC) establishes the following roles and responsibilities to ensure effective incident response coordination and management:

- **Incident Response Team (IRT)**

The Incident Response Team (IRT) is responsible for coordinating the identification, analysis, containment, eradication, and recovery of security incidents. The IRT operates in accordance with documented incident response procedures and playbooks.

The IRT shall:

- Serve as the primary authority for managing and responding to incidents
- Assess incident severity and determine appropriate response actions
- Coordinate with internal teams and external parties as needed
- Ensure incidents are documented, tracked, and resolved in accordance with established procedures

- **Information Technology (IT) & Security Teams (e.g., SOC)**

The IT and Security team support the Incident Response Team by maintaining system visibility, assisting in incident detection, and implementing response actions as directed.

- **Legal / Compliance**

The Legal and Compliance function is responsible for:

- Determining whether an incident meets the definition of a reportable breach
- Ensuring compliance with applicable laws, regulations, and contractual obligations
- Advising on regulatory reporting requirements and timelines

- **Senior Management / Approval Authority**

Senior Management provides oversight and decision-making authority for high-impact incidents.

Responsibilities include:

- Approving risk response decisions (e.g., mitigation, acceptance, or escalation)
- Allocating the resources necessary for incident response and recovery
- Providing executive-level direction during critical incidents

- **Human Resources (HR)**

Human Resources supports incident response efforts involving workforce members, including insider threat investigations and disciplinary action enforcement in accordance with organizational policies.

- **Public Relations (PR)**

Public Relations is responsible for managing external communications related to security incidents, including coordination of public statements, media responses, and stakeholder communications when required.

6. Incident Prioritization and Severity Ratings

Carraway Medical Center (CMC) classifies security incidents by severity to ensure appropriate prioritization, resource allocation, and response actions. Severity levels are determined based on the potential or actual impact to systems, data, operations, and patient safety. Severity classification may be adjusted as additional information becomes available during the incident response process.

Security Levels:

- **CMC L1 (Critical / Emergency)**

Incidents resulting in a complete disruption of critical services, significant data compromise, or immediate risk to patient safety or organizational operations. These incidents require immediate response, continuous engagement, and executive notification.

- **Examples:**

- Complete system outage affecting all users
 - Large-scale data breach involving sensitive information
 - Critical systems are unavailable or non-functional

- **CMC L2 (High / Major)**

Incidents that cause significant disruption to business operations or affect a large subset of users. These incidents require rapid response and dedicated resources.

- **Examples**

- Partial system outages affecting multiple users or departments
 - Degraded system performance is impacting operations
 - Unauthorized access to non-critical systems

- **CMC L3 (Medium / Moderate)**

Incidents with limited or localized impact that do not significantly disrupt critical operations. These incidents are addressed within standard business response timeframes.

- **Examples:**

- Malware detected on individual workstations
 - Phishing attempts identified and contained
 - Isolated service disruptions with available workarounds

- **CMC L4 (Low / Minor)**

Low-impact events or issues that do not affect critical operations and pose minimal risk to the organization.

- **Examples:**

- Minor system misconfigurations
- False positives or non-malicious alert
- General user-reported issues with no operational impact

Incident Prioritization

In addition to severity classification, incidents shall be prioritized based on their potential impact on patient safety, regulatory compliance, critical systems, and organizational operations. Periodization ensures that response efforts are directed toward the most critical risks first. Priority may differ from severity depending on regulatory obligations, business impact, and operational dependencies.

Priority Levels

PRIORITY 1 – Safety and Regulatory Impact

Incidents that pose a risk to patient safety, human life, or result in significant regulatory or legal exposure. This includes incidents involving unauthorized access, disclosure, or loss of sensitive or regulated data.

- **Examples:**

- Exposure or exfiltration of Protected Health Information (PHI)
- Incidents requiring regulatory notification
- Irrecoverable data loss involving sensitive information

PRIORITY 2 – Containment and Operational Stability

Incidents that significantly impact system functionality or data security and require immediate containment to prevent further damage.

- **Examples:**

- Active security threats requiring isolation or containment
- Unauthorized access to internal systems or data
- Incidents with uncertain recovery timelines

PRIORITY 3 – Critical Asset Protection and Recovery

Incidents affecting non-critical systems or localized environments that require remediation but do not pose immediate risk to patient safety or regulatory compliance.

- **Examples:**

- Localized system disruptions
- Limited data exposure with minimal operational impact
- Incidents with predictable recovery processes

7. Reporting and Contact Procedures

All Carraway Medical Center (CMC) workforce members, contractors, vendors, and third parties are required to report any suspected or confirmed security incidents promptly. Timely reporting is critical to ensure effective response and mitigation. Failure to report security incidents promptly may result in disciplinary action and increased organizational risk.

Reporting Channels

Incidents shall be reported using the following channels based on severity:

a) Critical and High-Severity Incidents

Incidents classified as Critical (L1) or High (L2) must be reported immediately to the CMC IT Service Desk, which operates 24/7, and logged through the official ticketing system using the appropriate severity classification.

- IT Service Desk: Extension #412
- Incident Response Team (On-Call Commander): Extension #654

b) Regulatory and Compliance-Related Incidents

Incidents involving suspected or confirmed exposure of Protected Health Information (PHI) or other regulated data must be reported to the Privacy Officer or Chief Information Security Officer (CISO) without delay.

- Privacy / Security Office: Extension #389

c) Standard Reporting (Non-Emergency)

Lower-severity incidents or suspicious activities (e.g., phishing attempts, account anomalies) must be reported through the IT Service Portal and categorized appropriately.

Reporting Requirements

All individuals must:

- Report incidents as soon as they are identified
- Provide accurate and complete information when submitting reports
- Refrain from attempting unauthorized investigation or remediation actions

Unauthorized actions may interfere with incident response efforts and compromise the integrity of evidence.

8. Supporting Forms and Documentation

Carraway Medical Center (CMC) maintains supporting documentation and resources to ensure consistent and effective incident response activities.

Incident Reporting and Documentation

All incidents must be documented using approved organizational tools and systems, including the CMC IT Service Portal and incident tracking systems.

Documentation shall include, at a minimum:

- Incident description and timeline
- Affected systems, data, or users
- Actions taken and response activities
- Resolution status and recovery details

All incident records must be retained in accordance with organizational data retention and regulatory requirements.

Related Security Controls and Standards

This policy aligns with applicable regulatory requirements and industry standards, including:

NIST SP 800-53 – Incident Response and Supporting Controls

- IR-1: Policy & Procedures
- IR-2: Incident Response Training
- IR-3: Incident Response Testing
- IR-4: Incident Handling
- IR-5: Incident Monitoring
- IR-6: Incident Reporting
- IR-7: Incident Response Assistance
- IR-8: Incident Response Plan
- IR-9: Information Spillage
- IR-10: Integrated Information Sharing
- AU-6: Audit Review & Analysis
- AC-2: Account Management
- IA-5: Authentication Management
- CM-3: Configuration Change Control
- SI-4: System Monitoring
- CP-2: Contingency Planning
- CP-10: System Recovery

HIPAA Security Rule

- HIPAA Security Incident Procedures 45 CFR 164.308(a)(6)

ISO/IEC 27001 – Incident Management Controls

- A.5.24 – Incident Management Planning
- A.5.25 – Assessment and Decision on Events
- A.5.26 – Response to Information Security Incidents
- A.5.27 – Learning from Incidents
- A.5.28 – Evidence Collection